



Botium Toys:

Scope, Goals, and Risk Assessment Report

Scope and goals of the audit

Scope: The scope of this audit is defined as the entire security program at Botium Toys. This includes their assets like employee equipment and devices, their internal network, and their systems. You will need to review the assets Botium Toys has and the controls and compliance practices they have in place.

Goals: Assess existing assets and complete the controls and compliance checklist to determine which controls and compliance best practices that need to be implemented to improve Botium Toys' security posture.

Current assets

Assets managed by the IT Department include:

- On-premises equipment for in-office business needs
- Employee equipment: end-user devices (desktops/laptops, smartphones), remote workstations, headsets, cables, keyboards, mice, docking stations, surveillance cameras, etc.
- Storefront products available for retail sale on site and online; stored in the company's adjoining warehouse
- Management of systems, software, and services: accounting, telecommunication, database, security, ecommerce, and inventory management
- Internet access
- Internal network
- Data retention and storage
- Legacy system maintenance: end-of-life systems that require human monitoring

Risk assessment

Risk description

Currently, there is inadequate management of assets. Additionally, Botium Toys does not have all of the proper controls in place and may not be fully compliant with U.S. and international regulations and standards.

Control best practices

The first of the five functions of the NIST CSF is Identify. Botium Toys will need to dedicate resources to identify assets so they can appropriately manage them. Additionally, they will need to classify existing assets and determine the impact of the loss of existing assets, including systems, on business continuity.

Risk score

On a scale of 1 to 10, the risk score is 8, which is fairly high. This is due to a lack of controls and adherence to compliance best practices.

Additional comments

The potential impact from the loss of an asset is rated as medium, because the IT department does not know which assets would be at risk. The risk to assets or fines from governing bodies is high because Botium Toys does not have all of the necessary controls in place and is not fully adhering to best practices related to compliance regulations that keep critical data private/secure. Review the following bullet points for specific details:

- Currently, all Botium Toys employees have access to internally stored data and may be able to access cardholder data and customers' PII/SPII.
- Encryption is not currently used to ensure confidentiality of customers' credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
- Access controls pertaining to least privilege and separation of duties have not been implemented.
- The IT department has ensured availability and integrated controls to ensure data integrity.
- The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
- Antivirus software is installed and monitored regularly by the IT department.

- The IT department has not installed an intrusion detection system (IDS).
- There are no disaster recovery plans currently in place, and the company does not have backups of critical data.
- The IT department has established a plan to notify E.U. customers within 72 hours if there is a security breach. Additionally, privacy policies, procedures, and processes have been developed and are enforced among IT department members/other employees, to properly document and maintain data.
- Although a password policy exists, its requirements are nominal and not in line with current minimum password complexity requirements (e.g., at least eight characters, a combination of letters and at least one number; special characters).
- There is no centralized password management system that enforces the password policy's minimum requirements, which sometimes affects productivity when employees/vendors submit a ticket to the IT department to recover or reset a password.
- While legacy systems are monitored and maintained, there is no regular schedule in place for these tasks and intervention methods are unclear.
- The store's physical location, which includes Botium Toys' main offices, store front, and warehouse of products, has sufficient locks, up-to-date closed-circuit television (CCTV) surveillance, as well as functioning fire detection and prevention systems.

Control categories

Control categories

Controls within cybersecurity are grouped into three main categories:

- Administrative/Managerial controls
- Technical controls
- Physical/Operational controls

Administrative/Managerial controls address the human component of cybersecurity. These controls include policies and procedures that define how an organization manages data and clearly defines employee responsibilities, including their role in protecting the organization. While administrative controls are typically policy based, the enforcement of those policies may require the use of technical or physical controls.

Technical controls consist of solutions such as firewalls, intrusion detection systems (IDS), intrusion prevention systems (IPS), antivirus (AV) products, encryption, etc. Technical controls can be used in a number of ways to meet organizational goals and objectives.

Physical/Operational controls include door locks, cabinet locks, surveillance cameras, badge readers, etc. They are used to limit physical access to physical assets by unauthorized personnel.

Control types

Control types include, but are not limited to:

1. Preventative
2. Corrective
3. Detective
4. Deterrent

These controls work together to provide defense in depth and protect assets.

Preventative controls are designed to prevent an incident from occurring in the first place. **Corrective controls** are used to restore an asset after an incident. **Detective controls** are implemented to determine whether an incident has occurred or is in progress. **Deterrent controls** are designed to discourage attacks.

Review the following charts for specific details about each type of control and its purpose.

Administrative/Managerial Controls		
Control Name	Control Type	Control Purpose
Least Privilege	Preventative	Reduce risk and overall impact of malicious insider or compromised accounts
Disaster recovery plans	Corrective	Provide business continuity
Password policies	Preventative	Reduce likelihood of account compromise through brute force or dictionary attack techniques
Access control policies	Preventative	Bolster confidentiality and integrity by defining which groups can access or modify data
Account management policies	Preventative	Managing account lifecycle, reducing attack surface, and limiting overall impact from disgruntled former employees and default account usage
Separation of duties	Preventative	Reduce risk and overall impact of malicious insider or compromised accounts

Technical Controls		
Control Name	Control Type	Control Purpose
Firewall	Preventative	To filter unwanted or malicious traffic from entering the network
IDS/IPS	Detective	To detect and prevent anomalous traffic that matches a signature or rule
Encryption	Deterrent	Provide confidentiality to sensitive information
Backups	Corrective	Restore/recover from an event
Password management	Preventative	Reduce password fatigue
Antivirus (AV) software	Preventative	Scans to detect and quarantine known threats
Manual monitoring, maintenance, and intervention	Preventative	Necessary to identify and manage threats, risks, or vulnerabilities to out-of-date systems

Physical/Operational Controls		
Control Name	Control Type	Control Purpose
Time-controlled safe	Deterrent	Reduce attack surface and overall impact from physical threats

Adequate lighting	Deterrent	Deter threats by limiting “hiding” places
Closed-circuit television (CCTV)	Preventative/Detective	Closed circuit television is both a preventative and detective control because it’s presence can reduce risk of certain types of events from occurring, and can be used after an event to inform on event conditions
Locking cabinets (for network gear)	Preventative	Bolster integrity by preventing unauthorized personnel and other individuals from physically accessing or modifying network infrastructure gear
Signage indicating alarm service provider	Deterrent	Deter certain types of threats by making the likelihood of a successful attack seem low
Locks	Deterrent/Preventative	Bolster integrity by deterring and preventing unauthorized personnel, individuals from physically accessing assets
Fire detection and prevention (fire alarm, sprinkler system, etc.)	Detective/Preventative	Detect fire in physical location and prevent damage to physical assets such as inventory, servers, etc.

Controls and Compliance Checklist

Controls assessment checklist

Yes	No	Control	Findings
☐	☒	Least Privilege	All employees currently have access to internal data, including cardholder data and customer PII/SPII.
☐	☒	Disaster recovery plans	There are no disaster recovery plans currently in place or existing backups of critical data.
☐	☒	Password policies	Password requirements are nominal and not in line with modern complexity standards. (e.g., at least eight characters, a combination of letters and at least one number; special characters)
☐	☒	Separation of duties	Access controls pertaining to least privilege and separation of duties have not been implemented.
☒	☐	Firewall	The IT department has a firewall that blocks traffic based on an appropriately defined set of security rules.
☐	☒	Intrusion detection system (IDS)	The IT department has not installed an intrusion detection system (IDS).
☐	☒	Backups	No existing backups of critical data.
☒	☐	Antivirus software	Antivirus software is installed and monitored regularly by the IT department.
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems	While legacy systems are maintained, there is no regular schedule for maintenance and intervention methods remain unclear.

☐	☒	Encryption	Encryption is not currently used to ensure confidentiality of customer credit card information that is accepted, processed, transmitted, and stored locally in the company's internal database.
☐	☒	Password management system	There is no centralized password management system that enforces the password policy's minimum requirements.
☒	☐	Locks (offices, storefront, warehouse)	The store's physical location (including main office, store front, and warehouse of products) has sufficient locks.
☒	☐	Closed-circuit television (CCTV) surveillance	The store's physical location (including main office, store front, and warehouse of products) has up-to-date closed-circuit television (CCTV) surveillance.
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)	The store's physical location (including main office, store front, and warehouse of products) has functioning fire detection and prevention systems.

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice	Comments
☐	☒	Only authorized users have access to customers' credit card information.	All employees currently have full internal data access.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.	Lack of encryption and basic access segregation.

☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.	Encryption is not used anywhere for cardholder data.
☐	☒	Adopt secure password management policies.	Password rules are nominal with no central manager.

General Data Protection Regulation (GDPR)

Yes	No	Best practice	Comments
☐	☒	E.U. customers' data is kept private/secured.	Data is unencrypted and accessible to all internal staff.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.	The IT department has established a plan to notify E.U. customers within 72 hours.
☐	☒	Ensure data is properly classified and inventoried.	The IT department does not know which assets are at risk.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.	Privacy policies, procedures, and processes have been developed and are enforced.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice	Comments
☐	☒	User access policies are established.	Least privilege and separation of duties are missing.
☐	☒	Sensitive data (PII/SPII) is	All staff can view

	confidential/private.	sensitive records.
☒	☐ Data integrity ensures the data is consistent, complete, accurate, and has been validated.	The IT department has ensured availability and integrated controls to ensure data integrity.
☒	☐ Data is available to individuals authorized to access it.	Availability controls are integrated and maintained.

Customer Recommendations:

1. **Implement Role-based Access Control & Least Privilege:** Restrict user access based on job roles to protect customer PII/SPII and cardholder data.
2. **Deploy Data Encryption:** Encrypt payment card data at rest and in transit to meet Payment Card Industry Data Security Standard (PCI DSS) compliance.
3. **Establish Backup & Recovery Protocols:** Create routine data backups and draft a formal Disaster Recovery Plan (DRP) to secure business continuity.
4. **Deploy a Password Management System:** Enforce complex passwords and Multi-factor Authentication (MFA) automatically across all staff accounts.
5. **Deploy an Intrusion Detection System (IDS):** Implement network-based or host-based intrusion detection systems to monitor internal traffic, log suspicious activity, and generate real-time security alerts.
6. **Establish a Scheduled Maintenance Framework for Legacy Systems:** Formalize a routine patching and monitoring schedule for legacy end-of-life systems, including defined manual intervention procedures to reduce operational risk. Also consider middleware to ensure operational uptime and reduce ETL breaks.
7. **Conduct Asset Classification and Inventory Management:** Perform a full inventory discovery to locate, classify, and tag all hardware, software, and data assets across the company to properly align with the NIST CSF Identify function.
8. **Implement Centralized Logging and SIEM Monitoring:** Deploy a centralized log aggregation tool (Security Information and Event Management) to track user activity,

monitor authentication attempts, and ensure audit trails for System and Organization Controls (SOC) 1 / SOC 2 compliance. Consider SIEMs like Splunk, Microsoft Sentinel, etc.

9. **Enforce Data Classification and Consent Controls for General Data Protection**

Regulation (GDPR): Establish clear data privacy policies, explicit user consent mechanisms for E.U. customers, and formal data mapping processes to meet GDPR mandates.

Examples of Current Business & Legal Risks:

1. **Regulatory Non-Compliance Fines:** Failing to encrypt cardholder data and customer details violates Payment Card Industry Data Security Standard (PCI DSS) and General Data Protection Regulation (GDPR) requirements, exposing the business to severe financial penalties and restricted payment processor access, including class action lawsuits.
2. **Operational Interruption & Unplanned Downtime:** The absence of a formalized Disaster Recovery Plan (DRP) and routine data backups leaves the company vulnerable to severe operational downtime, data loss, and revenue interruption during system outages or cyber incidents.
3. **Insider Threat & Unchecked Data Exposure:** Lacking the Principle of Least Privilege, Role-Based Access Control (RBAC), and separation of duties allows unauthorized employees broad access to sensitive customer Personally Identifiable Information (PII), increasing the risk of internal data leaks or accidental disclosure. Class action lawsuit risk.
4. **Contractual & Audit Vulnerability:** Inadequate user logging and missing System and Organization Controls (SOC 1 / SOC 2) standards limit transparency, leaving the organization unable to fulfill standard third-party vendor assessments or verify operational integrity.